



ZAP
by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://127.0.0.1:8001>

Generated on Fri, 12 Jun 2026 15:18:44

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	6
Low	5
Informational	12

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap. log file for details	11
Low	Exceeded High	http://127.0.0.1:8001	Percentage of slow responses	61 %
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://127.0.0.1:8001	Percentage of responses with status code 2xx	72 %
Info	Informational	http://127.0.0.1:8001	Percentage of responses with status code 3xx	1 %
Info	Exceeded Low	http://127.0.0.1:8001	Percentage of responses with status code 4xx	27 %
			Percentage of endpoints	

Info	Informational	http://127.0.0.1:8001	with content type text /html	80 %
Info	Informational	http://127.0.0.1:8001	Percentage of endpoints with content type text /plain	20 %
Info	Informational	http://127.0.0.1:8001	Percentage of endpoints with method GET	80 %
Info	Informational	http://127.0.0.1:8001	Percentage of endpoints with method POST	20 %
Info	Informational	http://127.0.0.1:8001	Count of total endpoints	5
Info	Informational	https://archive.mozilla.org	Percentage of responses with status code 2xx	100 %
Info	Informational	https://archive.mozilla.org	Percentage of slow responses	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	33 %
Info	Informational	https://cdnjs.cloudflare.com	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdnjs.cloudflare.com	Percentage of slow responses	33 %

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	4
CSP: script-src unsafe-eval	Medium	4
CSP: script-src unsafe-inline	Medium	4

CSP: style-src unsafe-inline	Medium	4
Content Security Policy (CSP) Header Not Set	Medium	1
Sub Resource Integrity Attribute Missing	Medium	Systemic
Big Redirect Detected (Potential Sensitive Information Leak)	Low	2
Cookie No HttpOnly Flag	Low	4
Cross-Domain JavaScript Source File Inclusion	Low	3
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	5
X-Content-Type-Options Header Missing	Low	4
Authentication Request Identified	Informational	2
Information Disclosure - Sensitive Information in URL	Informational	2
Modern Web Application	Informational	3
Session Management Response Identified	Informational	6
Tech Detected - Bootstrap	Informational	1
Tech Detected - Font Awesome	Informational	1
Tech Detected - PHP	Informational	1
Tech Detected - cdnjs	Informational	1
Tech Detected - jQuery	Informational	1
Tech Detected - jQuery CDN	Informational	1
Tech Detected - jsDelivr	Informational	1
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https://; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	http://127.0.0.1:8001/login
Node	

Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly broadly defined: img-src
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-eval
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website

	owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-eval.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-eval.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-eval.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_ token,email,password,remember)
Method	POST
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-eval.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
	https://www.w3.org/TR/CSP/

Reference	https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: script-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https://; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https://; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https://; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)

Method	POST
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	script-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	CSP: style-src unsafe-inline
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	style-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https;; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	style-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)

Method	GET
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https:; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	style-src includes unsafe-inline.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; img-src 'self' data: https:; font-src 'self' data: https://cdnjs.cloudflare.com https://cdn.jsdelivr.net; base-uri 'self'; form-action 'self'; frame-ancestors 'none';
Other Info	style-src includes unsafe-inline.
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8001/sitemap.xml
Node Name	http://127.0.0.1:8001/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

Reference	https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
Other Info	
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.min.css">
Other Info	
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
Other Info	

URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.min.css">
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Big Redirect Detected (Potential Sensitive Information Leak)
Description	The server has responded with a redirect that seems to provide a large response. This may indicate that although the server sent a redirect it also responded with body content (which may include sensitive details, PII, etc.).
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8001/login]. Predicted response size: 327. Response Body Length: 354.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	
Other Info	Location header URI length: 27 [http://127.0.0.1:8001/login]. Predicted response size: 327. Response Body Length: 354.
Instances	2
Solution	Ensure that no sensitive information is leaked via redirect responses. Redirect responses should have almost no content.
Reference	
CWE Id	201
WASC Id	13
Plugin Id	10044

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	Set-Cookie: XSRF-TOKEN
Other Info	
Instances	4
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.

URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	
Instances	3
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	X-Powered-By: PHP/8.4.1
Other Info	
URL	http://127.0.0.1:8001/login
Node	

Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	X-Powered-By: PHP/8.4.1
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	X-Powered-By: PHP/8.4.1
Other Info	
URL	http://127.0.0.1:8001/sitemap.xml
Node Name	http://127.0.0.1:8001/sitemap.xml
Method	GET
Attack	
Evidence	X-Powered-By: PHP/8.4.1
Other Info	
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	X-Powered-By: PHP/8.4.1
Other Info	
Instances	5
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037
Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8001/robots.txt
Node Name	http://127.0.0.1:8001/robots.txt
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	4
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.

Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password referrer=http://127.0.0.1:8001/login
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST
Attack	
Evidence	password
Other Info	userParam=email userValue=zaproxy@example.com passwordParam=password referrer=http://127.0.0.1:8001/login csrfToken=_token
Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on

Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	zaproxy@example.com
Other Info	The URL contains email address(es).
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	password
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: pass password
Instances	2
Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET

Attack	
Evidence	<script src="https://code.jquery.com/jquery-3.6.0.min.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login ()(_token,email,password,remember)
Method	POST

Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session cookie:XSRF-TOKEN
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	laravel-session
Other Info	cookie:laravel-session
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	
Evidence	XSRF-TOKEN
Other Info	cookie:XSRF-TOKEN
Instances	6
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	Tech Detected - Bootstrap
Description	The following "UI frameworks" technology was identified: Bootstrap. Described as: Bootstrap is a free and open-source CSS framework directed at responsive, mobile-first front-end web development. It contains CSS and JavaScript-based design templates for typography, forms, buttons, navigation, and other interface components.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css"
Other Info	The following CPE is associated with the identified tech: cpe:2.3:a:getbootstrap:bootstrap:*: ***** The following version(s) is/are associated with the identified tech: 5.3.0
Instances	1
Solution	
Reference	https://getbootstrap.com

CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - Font Awesome
Description	The following "Font scripts" technology was identified: Font Awesome. Described as: Font Awesome is a font and icon toolkit based on CSS and Less.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	/font-awesome/6.4.0/css/
Other Info	The following version(s) is/are associated with the identified tech: 6.4.0
Instances	1
Solution	
Reference	https://fontawesome.com/
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - PHP
Description	The following "Programming languages" technology was identified: PHP. Described as: PHP is a general-purpose scripting language used for web development.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	PHP/8.4.1
Other Info	The following CPE is associated with the identified tech: cpe:2.3:a:php:php:***:***:*** The following version(s) is/are associated with the identified tech: 8.4.1
Instances	1
Solution	
Reference	https://php.net
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - cdnjs
	The following "CDN" technology was identified: cdnjs.

Description	Described as: cdnjs is a free distributed JS library delivery service.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	
Reference	https://cdnjs.com
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - jQuery
Description	The following "JavaScript libraries" technology was identified: jQuery. Described as: jQuery is a JavaScript library which is a free, open-source software designed to simplify HTML DOM tree traversal and manipulation, as well as event handling, CSS animation, and Ajax.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	/jquery-3.6.0.
Other Info	The following CPE is associated with the identified tech: cpe:2.3:a:jquery:jquery:***** The following version(s) is/are associated with the identified tech: 3.6.0
Instances	1
Solution	
Reference	https://jquery.com
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - jQuery CDN
Description	The following "CDN" technology was identified: jQuery CDN. Described as: jQuery CDN is a way to include jQuery in your website without actually downloading and keeping it your website's folder.
URL	http://127.0.0.1:8001

Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	code.jquery.com/
Other Info	
Instances	1
Solution	
Reference	https://code.jquery.com/
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	Tech Detected - jsDelivr
Description	The following "CDN" technology was identified: jsDelivr. Described as: JSDelivr is a free public CDN for open-source projects. It can serve web files directly from the npm registry and GitHub repositories without any configuration.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	
Evidence	
Other Info	
Instances	1
Solution	
Reference	https://www.jsdelivr.com/
CWE Id	
WASC Id	13
Plugin Id	10004

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://127.0.0.1:8001
Node Name	http://127.0.0.1:8001
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	

URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://127.0.0.1:8001/login
Node Name	http://127.0.0.1:8001/login
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://127.0.0.1:8001/login?email=zaproxy%40example.com&password=ZAP&remember=on
Node Name	http://127.0.0.1:8001/login (email,password,remember)
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104